

Sustainable University IT

Technical and Operational Objections and Responses

An anticipatory argumentation module defending
the reference architecture, the sovereignty grid,
and the brownfield migration playbook

Companion to
"Sustainable University IT — A Technical Reference for Architecture and Migration"

SUIT suite version 1.0.3
Visibility: PUBLIC
Status: Approved by the approving academic units of the institution on *(approval date to be set)*
Based on the SUIT Working Group [1↗]
Print date: November 3, 2026

SUIT
International Working Group
on Sustainable University IT in the AI Era
(in formation)

This module addresses good-faith technical and operational objections to the Technical Reference. It is intended for chief technology officers, information-security officers, network and platform engineers, procurement officers, and the governance bodies that mandate them. Every response is constructed on five independent evidence layers — legal, standards, sector, empirical, and institutional — and remains generic across institutions and jurisdictions.

Note on the process:
This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.

This document contains a portion of imprecisions, missing content, errors or possibly hallucinations. We believe that a supportive and cooperative approach by the readers will make its content quality increase over time.

How to read this module

This module anticipates the **technical and operational** objections most likely to be raised against the Technical Reference (*Architecture and Migration*). It deliberately excludes political, budgetary-in-principle, and academic-freedom objections, which are treated in the policy-layer argumentation; here the question is always the same: *does the proposed engineering hold up under adversarial scrutiny?*

Each objection is stated in a **question box** in the words a sceptical engineer or architect would actually use. The response is given in a **answer box** that follows a strict **concession-then-rebuttal** pattern: it first concedes the legitimate core of the objection, then rebuts the overreach. Where a point needs disambiguation rather than refutation, an **clarification box** is used instead.

The five-layer evidence methodology. No response rests on assertion. Each rebuttal is built from up to five *independent* evidence layers, marked inline so the reader can audit the chain of support:

[Legal] binding legal and regulatory instruments of the adopter's jurisdiction (GDPR, NIS2 and sectoral law in the worked EU instantiation).

[Standards] open technical standards and normative frameworks (IETF, OASIS, NIST, ISO).

[Sector] higher-education and research-sector practice, toolkits, and sector bodies.

[Empirical] measured outcomes — breach data, incident reports, performance studies, cost figures.

[Institutional] named institutional precedents operating the relevant pattern in production.

A response is considered sound when at least *three* of these layers converge independently — the same minimum-three-layer rule applied throughout the suite.

Contents

How to read this module **i**

I Technical and Operational Objections **1**
1 Architecture complexity . . . 2
2 Open-source coverage gaps . . . 3
3 Sizing realism . . . 5
4 Brownfield migration and coexistence . . . 6
5 Vendor lock-in versus replaceability . . . 6
6 Conformance-test rigour . . . 7
7 Observability and audit load . . . 8
8 Reversibility . . . 9

II Quick-Reference Summary **11**
9 Objection map . . . 12

Bibliography **15**

Part I

Technical and Operational Objections

1 Architecture complexity

O1.1 — "The nine-layer architecture is over-engineered for a university."

The reference architecture decomposes the estate into nine layers — identity, network, compute, storage, observability, cryptography, orchestration, policy, endpoint — each with its own interface contract. A university is not a hyperscaler. This is enterprise-architecture theatre that no campus IT team can realistically operate; the layering adds cognitive load and failure modes without adding value.

Response O1.1

Concession. The objection is right that *a large number of moving parts is itself a risk.* Architectural complexity that is not matched by operational capacity degrades reliability rather than improving it; this is the central lesson of dependable-systems engineering, where each added component is an added fault source unless it is contained by a clear interface [2].

Rebuttal. The objection mistakes *decomposition* for *addition.* The nine layers are not nine new systems; they are nine *names for functions that already exist* in every university estate — identity, network, storage, and so on are present whether or not they are drawn as layers. The architecture does not add them; it makes their **interfaces explicit** so that complexity becomes *bounded and auditable* instead of tangled.

- **[Standards]** Layered decomposition behind stable interfaces is the canonical method for managing, not multiplying, complexity in secure systems engineering [2, 3]. ZERO TRUST architecture is itself defined as a set of separated planes (policy decision, policy enforcement, data) for exactly this reason [4].
- **[Sector]** The sector's own governance frameworks treat function-by-function decomposition as the prerequisite for manageability, not its enemy [5, 6].
- **[Institutional]** Research-intensive institutions already operate this decomposition in production — separated identity, network, and storage planes are visible, for example, at MIT [7, 8], STANFORD [9, 10], and UNIVERSITY OF MICHIGAN [11, 12]. None is a hyperscaler; all operate a layered decomposition along the same functional planes, whatever local labels they use.

Bottom line. The architecture does not impose nine systems on a campus that had one. It gives names and contracts to the functions a campus already runs, so the irreducible complexity is *governed* rather than *hidden.*

Clarification — complexity is instantiated to scale

The nine-layer *model* is invariant; its *instantiation* is not. A teaching-led institution may realise several layers as a single managed service or a hosted offering, collapsing operational surface while keeping the interface contracts intact (the Technical Reference (*Sizing reference points*)). The model is the vocabulary; the deployment is sized to the institution.

O1.2 — "Identity and policy become institution-wide single points of failure, with no availability story — a commercial SLA beats this."

Per-session policy decision routes every activation through the identity and policy planes. If either is down, nobody works. A managed commercial identity service at least carries a contractual SLA for that risk; the Reference proposes to self-operate the most critical planes of the institution.

Response O1.2

Concession. The mediation-point risk is real, and it is *created by the architecture itself*: making activation explicit concentrates what a flat estate leaves diffuse. Any deployment that treated the identity provider or the policy decision point as ordinary single-instance services would deserve this objection in full.

Rebuttal. The Reference engineers the risk rather than insuring against it (the Technical Reference (*Architectural principles*), availability and failure semantics of the mediation planes): each critical plane runs redundantly with a declared availability target measured through the observability layer; policy enforcement points cache decisions for the activation-token lifetime, so a policy-plane outage blocks *new* activations without invalidating established sessions; and each zone class declares its fail mode (fail-closed for administrative and sensitive zones, fail-degraded with audit where connectivity availability prevails).

- **[Standards]** Zero-trust guidance itself requires exactly this engineering: NIST SP 800-207 treats PDP/PEP availability and decision caching as design obligations of the model [4].
- **[Standards]** The reference components are built for clustered operation — replicated identity providers, policy engines evaluating from locally distributed bundles [13] — so redundancy is configuration, not custom engineering.
- **[Institutional]** The failure semantics are testable, not asserted: availability targets are measured by the observability layer, and the fail-mode declarations are part of each zone's published security profile, exercised through the conformance suite (the Technical Reference (*Conformance and replaceability tests*)).

Bottom line. An SLA is a remedy after the fact; declared, rehearsed failure semantics are a design. The architecture does not leave the mediation planes' availability to contract — it engineers it, measures it, and makes outage behaviour a per-zone-class policy choice.

2 Open-source coverage gaps

O2.1 — "Open-source MDM cannot manage iOS and Android, so the open-foundations claim is false."

The whole document rests on a reference instantiation built on open foundations. But there is no credible open-source mobile-device-management stack for iOS and Android at scale. The moment a university has a real fleet of phones and tablets, it must buy a proprietary suite. The "open foundations" claim collapses at the endpoint.

Response O2.1

Concession. This is the strongest technical objection in the document, and it is conceded *in full on the facts*. There is no mature open-source MDM that matches a commercial suite for supervised iOS and managed Android at fleet scale. Open tooling for Apple platforms is real and production-grade for enrolment and software management [14, 15], and osquery provides open posture telemetry across operating systems [16]; but a turnkey, vendor-supported mobile MDM on fully open foundations does not exist today. The Technical Reference says exactly this, in the open, rather than hiding it.

Rebuttal. The objection then over-reaches: it treats one bounded gap as the collapse of the whole. The open-foundations claim is a claim about **replaceability through contracts**, not about purism. The architecture's test is not "is every component open?" but "can every component be replaced without re-architecting?" — and a proprietary MDM that exports

configuration profiles to a documented format and feeds posture to the policy plane through a standard interface *passes that test*.

- **[Standards]** The endpoint contract is defined by open interfaces, not by the product behind them: posture and identity flow over SCIM [17], OIDC [18], and standard telemetry — so a proprietary suite is a conforming *instantiation*, not an exception.
- **[Sector]** The sector already procures exactly this way: the HECVAT toolkit exists precisely because universities buy assessed proprietary endpoint products under a common contract [19]. Commercial suites such as [20, 21] are named in the reference as legitimate instantiations for the iOS/Android portion of the estate.
- **[Empirical]** Endpoint compromise — not MDM ideology — is where the measured risk lives: ransomware and credential-driven breaches dominate education-sector incident data [22, 23]. The architecture prioritises *posture and replaceability* over provenance precisely because that is what the breach data rewards.
- **[Institutional]** Mixed open/proprietary endpoint estates are common at research-intensive institutions, which run a dedicated Apple-platform suite alongside open configuration management and osquery for Linux and servers (MIT, Stanford, University of Michigan [7, 9, 24]).

Bottom line. The iOS/Android MDM gap is real and acknowledged. It does not falsify the open-foundations claim, because that claim is about **contract-bounded replaceability**, and a proprietary MDM that honours the endpoint interface contract is a conforming instantiation, not a counter-example.

O2.2 — "Open source is itself the supply-chain risk: unmaintained dependencies, no vendor CVE-response SLA, nobody to sue."

The open-foundations default trades a contractual security relationship for a volunteer one. Open components ship unmaintained transitive dependencies, carry no committed CVE-response time, and offer no counterparty bearing liability when something breaks.

Response O2.2

Concession. The failure mode is real: abandonware exists, and an open licence confers no right to a fix. A deployment that consumed anonymous code with no support arrangement, no provenance control, and no maintenance assessment would deserve the objection in full.

Rebuttal. The architecture does not consume anonymous code; it procures open components under the same discipline as any supplier.

- **[Sector]** Where a committed CVE-response time is required, the institution buys a commercial support subscription for the open component — procured and assessed like any vendor relationship [19]; the counterparty exists, and what remains open is the exit.
- **[Standards]** Supply-chain provenance is a named control, not a hope: SLSA provenance for built artefacts [25], with the supply-chain-security ownership established for NIS2 Art. 21(2)(d) by the policy module's Q8.5.
- **[Institutional]** The sovereignty grid's *Operational* dimension scores maintenance reality — skills, community, certification paths — per layer *before* adoption (the Technical Reference (*The sovereignty grid*)); a component nobody can sustain scores itself out.
- **[Standards]** "Nobody to sue" cuts both ways: a contractual remedy does not produce a patch, while source access and the replaceability conditions (O5.1) let the institution

patch, fork, or replace — bounding the blast radius of any single project's abandonment.

Bottom line. Supply-chain risk attaches to unmanaged consumption, not to licence type. The architecture pairs open components with support contracts where SLAs matter, provenance controls where builds matter, and an operational-sustainability score before adoption — with replaceability as the final backstop.

3 Sizing realism

O3.1 — "The sizing reference points are fantasy; a small university cannot run this."

The architecture may suit a flagship research university with hundreds of network engineers, but it is unaffordable and unstaffable for a small teaching-led institution. Prescribing a nine-layer estate to a college with a five-person IT team is sizing fantasy.

Response O3.1

Concession. Conceded that *a one-size instantiation would be fantasy.* A small institution genuinely cannot operate the same realisation as a multi-petabyte research university, and any document that demanded it would be unserious about operations.

Rebuttal. The architecture does not demand a single realisation. It distinguishes the **minimal necessary functional set** — which is size-invariant — from its **instantiation** — which scales. The functions an institution must perform (authenticate subjects, segment the network, classify and protect data, retain auditable logs) do not disappear at small scale; they are simply realised more compactly, often as managed or hosted services. This is a guardrail *against* overclaim, not an instance of it.

- [Legal] The size-invariant core is anchored in law — the institution's applicable data-protection regime and the applicable supranational and national legal framework, worked here through the EU instruments: GDPR imposes accountability, security of processing, and breach obligations with *no de-minimis threshold* — a five-person institution owes the same duties as a flagship [26]. (The one narrow size-based relief, the records-of-processing derogation for organisations below 250 persons under Article 30(5), is itself conditional and does not touch the security, accountability, or breach duties at issue here.) NIS2 likewise scales nothing down: once an entity is in scope (by sector-and-size, or by a size-independent designation route), its duties apply in full regardless of headcount [27].
- [Standards] The minimal set maps to baseline controls that are stated independently of scale [4, 28, 29]; the controls are mandatory, the deployment topology is sized.
- [Sector] EDUCAUSE governance guidance frames IT provision as a function of mission and risk, explicitly supporting shared-service and consortial realisations for smaller institutions [30, 31].
- [Institutional] National research and education networks (e.g. GÉANT, RENATER, RESTENA in Europe) exist precisely so that small institutions consume identity, connectivity, and security as shared services rather than building them alone [32, 33, 34, 35, 36].

Bottom line. The minimal functional set is size-invariant because the *obligations* are; the instantiation scales down to managed and shared services. The sizing chapter prescribes envelopes, not a single mandatory plant.

4 Brownfield migration and coexistence

O4.1 — "This is a greenfield design; no real university can rip-and-replace its estate."

The wave-based playbook reads like a clean-sheet build. Real universities have decades of accreted systems, in-flight contracts, and departments that will not be coordinated. A migration that assumes you can stop the world and rebuild is dead on arrival.

Response O4.1

Concession. Conceded that *a rip-and-replace migration would fail.* Estates are heterogeneous, contracts are mid-term, and federated governance means no central team can mandate a flag day. Any playbook that ignored this would be unusable.

Rebuttal. The objection describes a design the Technical Reference explicitly rejects. The playbook is **brownfield by construction**: it is wave-based precisely so that each step is independently valuable, reversible, and *coexists* with incumbent systems. A dedicated coexistence-patterns library and a reversibility playbook exist for exactly the heterogeneity the objection raises (the Technical Reference (*Coexistence patterns library*); the Technical Reference (*Reversibility playbook*)).

- **[Standards]** Incremental adoption behind stable interfaces is the standard path for cyber-resilient transformation [3]; ZERO TRUST migration is itself specified as incremental and coexistence-friendly, never as a flag day [4].
- **[Sector]** Sector governance treats migration as portfolio change managed against mission risk, not as a single cutover [5, 30, 37].
- **[Empirical]** The waves are ordered to address the most-exploited attack patterns first: identity, segmentation, and observability lead because credential abuse dominates measured breach data [23, 38] and segmentation interrupts its in-network progression [39]. The ordering is an evidence-informed prioritisation of the measured exposure, so early waves buy down the most-exploited risk before any large investment.
- **[Institutional]** Coexistence is the lived reality at research-intensive institutions such as MIT and UNIVERSITY OF MICHIGAN, where federated identity overlays a heterogeneous estate [8, 11], and SCIENCE DMZ deployments coexist with the general campus network rather than replacing it [40, 41].

Bottom line. The playbook is the opposite of greenfield: each wave is independently valuable and reversible, and coexistence with incumbents is a first-class design goal, not an afterthought.

5 Vendor lock-in versus replaceability

O5.1 — "Standardising on a stack just swaps one lock-in for another."

You criticise proprietary lock-in, then prescribe a specific open stack — a particular identity provider, a particular orchestrator, a particular storage system. That is still lock-in; you have only changed the vendor. The "replaceability" claim is rhetorical.

Response O5.1

Concession. Conceded that *naming open products does not by itself defeat lock-in.* An open component can still trap an institution through bespoke configuration, undocumented data formats, or unique operational dependencies. Open licensing is necessary but not sufficient for replaceability; status-quo bias makes any incumbent — open or not — sticky [42].

Rebuttal. The architecture does not claim replaceability *from* choosing open products. It claims replaceability *from* four explicit conditions enforced by a conformance suite: standard interfaces, open state and configuration formats, documented exit-data export, and no hidden dependencies. The named open instantiation is an *example* that satisfies these conditions; a proprietary component that satisfies the same conditions is equally acceptable. Lock-in is defeated by the **contract**, not by the **logo**.

- **[Standards]** Every layer's interface is pinned to an open standard — OIDC/SAML/SCIM for identity [17, 18, 43], KMIP/PKCS#11 for key management [44, 45], TLS 1.3 and ACME on the wire [46, 47], OpenTelemetry and IPFIX for telemetry [48, 49], and OCI image formats for workloads [50]. Replaceability is the property of conforming to these, regardless of the product.
- **[Legal]** Replaceability is also a compliance asset: GDPR portability and the ability to change processors presuppose that data can leave a system in a usable form [26]; standard-contractual and processor-change mechanisms assume exit is possible [51].
- **[Sector]** HECVAT institutionalises exactly this vendor-neutral, contract-based assessment for the sector [19].
- **[Institutional]** Multi-vendor, standards-pinned identity federations (eduGAIN and eduroam globally, with regional federations such as InCommon) demonstrate that replaceability through interfaces is an operating reality, not a slogan [35, 36, 52].

Bottom line. The defence against lock-in is the four replaceability conditions and the conformance suite that tests them — not allegiance to any product, open or proprietary.

6 Conformance-test rigour

O6.1 — "The conformance tests are a checklist, not a real guarantee."

"Replaceability conditions" and a "conformance day" sound reassuring, but a checklist is not proof. Without an enforced, repeatable, and independently verifiable test, conformance is a self-graded exercise that every vendor will claim to pass.

Response O6.1

Concession. Conceded that *an unenforced checklist is worthless.* A conformance claim that cannot be re-run by a third party, on representative data, is marketing. Self-attestation without evidence is a known failure mode in procurement.

Rebuttal. The conformance suite is specified as an **executable, evidence-producing test** to be run by the adopting institution, not a questionnaire. It defines categories of test — interface fidelity, data portability, exit rehearsal, and decision auditability — each of which yields an artefact: a captured export consumed by an alternative, a replay against a documented schema, a recorded migration on a representative subset (the Technical Reference (*Conformance and replaceability tests*)). The test is passed by *producing the artefact*, not by asserting compliance. Where sound practice makes a nominal artefact unobtainable —

non-exportable HSM trust-anchor keys being the canonical case — the layer contract declares the substitute artefact (a key-rotation and re-anchoring rehearsal under dual control), so the gate is passable without weakening key custody.

- **[Standards]** Conformance-to-interface as the unit of verification is the standard discipline: the open interfaces themselves (SCIM, KMIP, OCI, OpenTelemetry) carry normative conformance criteria that a test can mechanically check [17, 44, 48, 50].
- **[Sector]** The sector already operates standardised, repeatable third-party assessment through HECVAT, and research cybersecurity centres publish reusable assessment methods [19, 53].
- **[Empirical]** Tests are weighted toward the data: control categories track the attack patterns that actually cause breaches — exfiltration paths, credential reuse, and unpatched transfer software — as reported in incident data [23, 54].
- **[Institutional]** The artefact-based discipline is already routine in the sector, if for a different property: perfSONAR and Science DMZ deployments verify end-to-end behaviour against measured baselines rather than vendor claims [40, 55, 56]. This establishes that re-runnable, evidence-producing conformance is an operating norm on the research network, the same discipline the replaceability suite applies to exit and portability.

Bottom line. Conformance is defined as the production of a re-runnable artefact against an open interface, not a self-graded checklist; the artefact is what a third party verifies.

7 Observability and audit load

O7.1 — "Mandating observability everywhere creates a surveillance and cost burden."

The observability layer asks for logs, traces, and metrics across the estate. That is a privacy hazard, a storage cost explosion, and an alert-fatigue generator. The audit load you create may be worse than the threats you mitigate.

Response O7.1

Concession. Conceded that *indiscriminate collection is harmful.* Collecting everything is a privacy hazard, a storage liability, and a path to alert fatigue — and over-collected personal data is itself a compliance and breach-exposure risk, not a control.

Rebuttal. The objection conflates *indiscriminate* collection with *purpose-bound, classified* observability. The architecture specifies observability tied to data classification and retention policy: what is collected, why, for how long, and who may read it are constrained by design, not maximised (the Technical Reference (*Observability and audit*)). Auditability is a legal obligation that exists independently of this document; the architecture discharges it *proportionately* rather than maximally.

- **[Legal]** Security of processing and breach-detection duties under GDPR [26] and the technical risk-management requirements of NIS2 [27] *require* adequate logging — with the Commission's technical articulation for digital-sector entities applied here by analogy [57]; the same legal frame caps it through data minimisation and purpose limitation [26]. Audit is mandated; over-collection is prohibited — proportionality is the lawful design point.
- **[Standards]** Detect-and-respond functions are baseline controls [28, 29, 58]; structured, standard telemetry (syslog, IPFIX, OpenTelemetry) makes collection efficient and

bounded rather than sprawling [48, 49, 59].

- **[Empirical]** Breach economics reward exactly this: faster detection and containment measurably reduce breach cost — breaches contained faster cost measurably less, the breach lifecycle being a major cost driver [23, 38]. Proportionate observability is the highest-return control, not overhead.
- **[Institutional]** Research universities run classification-driven observability in production through their security operations and incident-response capabilities [9, 24], and the sector operates shared trust and incident infrastructure (e.g. REN-ISAC in the US, FIRST globally) on this basis [60, 61].

Bottom line. The mandate is proportionate, classified observability — legally required to exist and legally bounded in extent — not blanket surveillance; the standard telemetry interfaces keep its cost bounded.

8 Reversibility

O8.1 — "Reversibility is a comforting promise that never survives contact with production."

You promise that each wave is reversible. In practice, once identity, network, and policy changes are live, rolling back is a fantasy — the dependencies entangle, the data has moved, and nobody dares revert. The reversibility playbook is reassurance, not engineering.

Response O8.1

Concession. Conceded that *reversibility is not free and is often claimed without being engineered.* A rollback that was never designed, rehearsed, or tested will indeed fail under pressure, and entangled dependencies can make a naive revert impossible.

Rebuttal. That is precisely why reversibility is treated as a **designed and rehearsed property**, not an aspiration. Each wave defines its rollback preconditions, its data-preservation guarantees, and a tested revert path *before* the wave is committed; coexistence with the incumbent during a wave is what keeps the revert path open (the Technical Reference (*Reversibility playbook*); the Technical Reference (*Coexistence patterns library*)). Reversibility here is a fault-tolerance requirement, engineered like any other.

- **[Standards]** Designed recoverability and graceful rollback are core cyber-resilience and dependable-systems requirements, not optional extras [2, 3]; resilient systems are specified to fail back to a known-good state.
- **[Legal]** Reversibility is also a continuity and exit obligation: processor-change and data-portability provisions presuppose that a configuration can be unwound and data recovered in usable form [26, 51].
- **[Sector]** Change managed with explicit rollback gates is standard IT governance practice [5, 6].
- **[Institutional]** Coexistence-based migrations preserve the revert path in production: Science DMZ runs alongside the general network so the institution can fall back, and federated identity overlays — rather than replaces — incumbent systems during transition [8, 11, 40, 41].

Bottom line. Reversibility is engineered and rehearsed per wave, and kept open by coexistence with the incumbent — it is a fault-tolerance requirement, not a comforting promise.

Part II

Quick-Reference Summary

9 Objection map

The table below summarises every objection in this module, its concession, the dominant evidence layers, and the one-line rebuttal. **[Legal]** Legal, **[Standards]** Standards, **[Sector]** Sector, **[Empirical]** Empirical, and **[Institutional]** Institutional mark the converging evidence layers used in each response (minimum three per response).

ID	Objection	Conceded core	Evidence	One-line rebuttal
O1.1	Architecture is over-engineered for a university	Unmatched complexity is a real risk	Std, Sector, Inst	Layers name functions a campus already runs; contracts *bound* complexity, not add it.
O1.2	Identity/policy are single points of failure; an SLA beats this	Mediation-point risk is real and architecture-created	Std, Inst	Redundancy per plane, PEP caching over token lifetime, declared per-zone fail modes — engineered, measured, rehearsed.
O2.1	Open-source MDM cannot manage iOS/Android	No mature open mobile MDM at scale (true)	Legal, Std, Sector, Emp, Inst	Open-foundations means contract-bounded replaceability; a conforming proprietary MDM is a valid instantiation.
O2.2	Open source is itself the supply-chain risk	Abandonware is real; a licence confers no fix	Std, Sector, Inst	Support subscriptions where SLAs matter, SLSA provenance, Operational-dimension scoring, replaceability as backstop.
O3.1	Sizing is fantasy for small institutions	One-size instantiation would be unserious	Legal, Std, Sector, Inst	Minimal functional set is size-invariant (no-threshold law); instantiation scales to shared/managed services.
O4.1	Greenfield design; no rip-and-replace is possible	Rip-and-replace would fail	Std, Sector, Emp, Inst	Playbook is brownfield by construction: waves coexist with incumbents and are independently valuable.
O5.1	Open stack just swaps one lock-in for another	Open licensing alone does not defeat lock-in	Legal, Std, Sector, Inst	Replaceability comes from four conditions + conformance tests, not from the logo.
O6.1	Conformance tests are a checklist, not a guarantee	An unenforced checklist is worthless	Std, Sector, Emp, Inst	Conformance = a re-runnable artefact against an open interface, third-party verifiable.
O7.1	Observability is surveillance and cost burden	Indiscriminate collection is harmful	Legal, Std, Emp, Inst	Mandate is proportionate, classified observability — legally required and legally bounded.

continued on next page

ID	Objection	Conceded core	Evidence	One-line rebuttal
O8.1	Reversibility never survives production	Un-rehearsed roll-back fails	Legal, Std, Sector, Inst	Reversibility is designed and rehearsed per wave, kept open by coexistence.

Methodological note. Every response in this module concedes the legitimate core of its objection before rebutting the overreach, and each rests on at least three independent evidence layers. The recurring defensive structure — *size-invariant minimal functional set*, *contract-bounded replaceability*, and *brownfield coexistence* — is what allows the architecture to be simultaneously rigorous and applicable across institutions of very different scale and jurisdiction.

Bibliography

[1] SUIT Working Group. *SUIT — Sustainable University IT Infrastructure & Technology*. SUIT Working Group reference document suite. Reference document suite of the SUIT Working Group, https://github.com/suit-working-group. Always-living document. 2026. URL: https://github.com/suit-working-group/suit-suite.

[2] Algirdas Avizienis, Jean-Claude Laprie, Brian Randell, and Carl Landwehr. "Basic Concepts and Taxonomy of Dependable and Secure Computing". In: *IEEE Transactions on Dependable and Secure Computing* 1.1 (2004). Seminal taxonomy paper that formalises dependability as an integrating concept encompassing availability, reliability, safety, integrity, maintainability, and security. Introduces the orthogonal classification of threats (faults, errors, failures), attributes, and means (prevention, tolerance, removal, forecasting)., pp. 11–33. DOI: 10.1109/TDSC.2004.2. URL: https://ieeexplore.ieee.org/document/1335465.

[3] Ron Ross, Victoria Pillitteri, Richard Graubart, Deborah Bodeau, and Rosalie McQuaid. *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. Tech. rep. NIST SP 800-160 Vol. 2 Rev. 1. Fourteen cyber-resiliency techniques including segmentation. Foundational reference for university IT architecture resilience. National Institute of Standards and Technology, 2021. DOI: 10.6028/NIST.SP.800-160v2r1. URL: https://csrc.nist.gov/publications/detail/sp/800-160/vol-2-rev-1/final.

[4] Scott Rose, Oliver Borchert, Stu Mitchell, and Sean Connelly. *Zero Trust Architecture*. Tech. rep. NIST SP 800-207. This framework is particularly relevant for university IT infrastructure as institutions increasingly support remote work, personal devices, and cloud-based services that fall outside traditional network boundaries, necessitating resource-level protection rather than perimeter-based defenses. National Institute of Standards and Technology, Aug. 2020. DOI: 10.6028/NIST.SP.800-207. URL: https://csrc.nist.gov/publications/detail/sp/800-207/final.

[5] ISACA. *COBIT 2019 Framework: Introduction and Methodology*. For universities, COBIT offers tools for optimizing IT governance, managing risks, establishing controls, and supporting digital transformation initiatives critical to protecting institutional data and ensuring regulatory compliance. ISACA, 2018. URL: https://www.isaca.org/resources/cobit.

[6] Steven De Haes and Wim Van Grembergen. *Enterprise Governance of Information Technology*. 2nd. Management for Professionals. Directly relevant to university IT governance as it defines processes and structures that enable boards and IT professionals to align technology decisions with institutional strategic objectives. Springer, 2015. DOI: 10.1007/978-3-319-14547-1. URL: https://link.springer.com/book/10.1007/978-3-319-14547-1.

[7] MIT Information Systems & Technology. *About IS&T*. Massachusetts Institute of Technology. Original description extracted from ist.mit.edu/about landing page. — AI-generated contextual summary: IS&T is the central IT organization of MIT, managing MITnet, cloud and hybrid infrastructure, enterprise applications, security operations, and end-user support, documenting the organizational model and strategic direction of a world-leading university's centralized IT department. URL: https://ist.mit.edu/about.

[8] S. P. Miller, B. Clifford Neuman, Jeffrey I. Schiller, and Jerome H. Saltzer. *Kerberos Authentication and Authorization System*. Tech. rep. Section E.2.1. Original abstract from the technical report (verified via Semantic Scholar). — AI-generated contextual summary: Kerberos uses a trusted third-party ticket-granting mechanism to allow users and services to prove their identity without transmitting passwords over the network. Developed as a core component of the Athena campus computing project, Kerberos became a foundational technology for university IT infrastructure and has since been adopted as a standard authentication protocol across higher education and enterprise environments worldwide. MIT Project Athena Technical Plan, 1987. URL: https://web.mit.edu/Saltzer/www/publications/athenaplan/e.2.1.pdf.

[9] Stanford University IT. *University IT (UIT)*. Stanford University. Original description extracted from uit.stanford.edu/about. — AI-generated contextual summary: UIT serves as the central IT support hub connecting students, faculty, and staff with technology services across the university, functioning as a centralized gateway for IT help, training, and announcements relevant to digital infrastructure and cybersecurity initiatives. URL: https://uit.stanford.edu/.

[10] Stanford University IT. *SUNet — Stanford University Network*. Stanford University. Original description extracted from uit.stanford.edu/service/network. — AI-generated contextual summary: SUNet outlines connectivity responsibilities shared between University IT and individual departments, serving as a comprehensive reference for IT providers with links to network-related services including VPN, firewalls, Wi-Fi, and cloud networking solutions. URL: https://uit.stanford.edu/service/network.

[11] University of Michigan — ITS. *About ITS*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Information and Technology Services (ITS) is the central IT organization providing shared technology services and infrastructure to the university community. ITS supports core enterprise systems, networking, security, and digital services that underpin academic, research, and administrative operations across all three campuses. URL: https://its.umich.edu/about.

[12] University of Michigan — ITS. *Core Network*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Core Network is the high-speed backbone network infrastructure managed by ITS that interconnects campus buildings, data centers, and external research networks. It provides essential wired and wireless connectivity supporting academic, research, and administrative computing across the university's campuses. URL: https://its.umich.edu/enterprise/wifi-networks/core-network.

[13] Open Policy Agent Project. *Open Policy Agent (OPA)*. CNCF graduated project documentation. 2024. URL: https://www.openpolicyagent.org/.

[14] MicroMDM Project. *MicroMDM: Mobile Device Management for Apple platforms*. Open-source project documentation. 2024. URL: https://micromdm.io/.

[15] Munki Project. *Munki: Managed software installation for macOS*. Open-source project documentation. 2024. URL: https://www.munki.org/munki/.

[16] osquery Project. *osquery: Performant endpoint visibility*. Linux Foundation project documentation. 2024. URL: https://osquery.io/.

[17] P. Hunt, K. Grizzle, E. Wahlstroem, and C. Mortimore. *System for Cross-domain Identity Management: Core Schema*. RFC 7643, Internet Engineering Task Force. 2015. URL: https://datatracker.ietf.org/doc/html/rfc7643.

[18] N. Sakimura, J. Bradley, M. Jones, B. de Medeiros, and C. Mortimore. *OpenID Connect Core 1.0 incorporating errata set 2*. OpenID Foundation specification. 2023. URL: https://openid.net/specs/openid-connect-core-1_0.html.

[19] EDUCAUSE. *Higher Education Community Vendor Assessment Toolkit (HECVAT)*. EDUCAUSE. The HECVAT is a common framework widely adopted across higher education that speeds up the procurement process for companies and institutions. Specifically designed for the higher education sector to ensure that institutional data is appropriately secured when using external technology solutions and cloud services. 2020. URL: https://www.educause.edu/higher-education-community-vendor-assessment-toolkit.

[20] Jamf Software. *Jamf: Apple device management*. Commercial MDM product documentation. 2024. URL: https://www.jamf.com/.

[21] Microsoft. *Microsoft Intune*. Commercial unified endpoint management documentation. 2024. URL: https://learn.microsoft.com/intune/.

[22] Sophos. *The State of Ransomware in Education 2025*. Sophos. Explores the technical and organizational root causes of attacks, encryption rates, ransom demands, and the human impact on security teams. Critical resource for university IT leaders seeking to understand vulnerability patterns and develop institutional defenses against increasingly sophisticated ransomware threats targeting the education sector. 2025. URL: https://www.sophos.com/en-us/whitepaper/state-of-ransomware-in-education.

[23] Verizon Business. *2024 Data Breach Investigations Report*. Verizon. Comprehensive annual analysis of cybersecurity incidents and data breaches across multiple industry sectors, including education. Draws on thousands of real-world incidents, identifies prevailing attack patterns, threat actor profiles, and vulnerability exploitation trends. Findings on ransomware prevalence, credential theft, and social engineering are directly applicable to university cybersecurity governance and risk management strategies. 2024. URL: https://www.verizon.com/business/resources/reports/dbir.html.

[24] University of Michigan. *Safe Computing — Data Classification Levels*. University of Michigan. Site blocks bots with HTTP 403; no original description recoverable. — AI-generated contextual summary: the University of Michigan Safe Computing website defines the institution's data classification framework, categorizing institutional data into sensitivity levels (High, Moderate, Low) to guide appropriate handling, storage, and protection measures. This classification system establishes security requirements proportional to data sensitivity, covering everything from public information to regulated data such as HIPAA and FERPA records. The framework is central to the university's cybersecurity governance, enabling consistent data protection policies across a large, decentralized institution. URL: https://safecomputing.umich.edu/protect-the-u/safely-use-sensitive-data/classification-levels.

[25] Open Source Security Foundation (OpenSSF). *Supply-chain Levels for Software Artifacts (SLSA)*. OpenSSF specification. 2024. URL: https://slsa.dev/.

[26] *Règlement (UE) 2016/679 du Parlement européen et du Conseil relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD)*. Article 32 : Sécurité du traitement — The GDPR imposes compliance requirements on student and employee data handling, research data management, cybersecurity incident response protocols, and IT infrastructure standards. Article 32 specifically mandates appropriate technical and organizational security measures. 2016. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32016R0679.

[27] *Directive (UE) 2022/2555 du Parlement européen et du Conseil concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS2)*. Universities operating data centers, cloud services, or critical research networks may fall within the directive's scope, requiring them to structure cybersecurity governance and risk management in compliance with its provisions. 2022. URL: https://eur-lex.europa.eu/legal-content/FR/TXT/?uri=CELEX:32022L2555.

[28] NIST. *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. The CSF 2.0 is a foundational tool for academic institutions seeking to establish or enhance their cybersecurity governance posture and align risk management efforts with standardized best practices across all sectors. National Institute of Standards and Technology, Feb. 2024. DOI: 10.6028/NIST.CSWP.29. URL: https://www.nist.gov/cyberframework.

[29] ISO/IEC. *ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements*. ISO/IEC 27001:2022 is the world's best-known standard for information security management systems (ISMS). For universities, it provides a comprehensive framework for managing information security risks across IT infrastructure, research data, and institutional operations. The 2022 revision updates the standard to address emerging threats in cloud security and data privacy. 2022. URL: https://www.iso.org/standard/27001.

[30] EDUCAUSE. *IT Governance in Higher Education*. EDUCAUSE. The EDUCAUSE IT Governance resource collection provides frameworks, toolkits, checklists, and case studies for implementing effective IT governance, risk, and compliance (GRC) programs in higher education institutions, including the IT Governance Toolkit and the Higher Education IT Governance Checklist. URL: https://library.educause.edu/topics/it-professional-services/it-governance.

[31] EDUCAUSE/HEISC. *Information Security Guide*. EDUCAUSE. Formerly the Information Security Guide. Created by practitioners for practitioners, it is an essential resource for colleges and universities seeking to develop or strengthen their information security and privacy programs in alignment with sector-specific threats and regulatory requirements. URL: https://www.educause.edu/cybersecurity-and-privacy-guide.

[32] GÉANT. *GÉANT — Pan-European Research and Education Network*. Original description extracted from about.geant.org/about/ (main site blocks bots with 403). — AI-generated contextual summary: GÉANT provides critical infrastructure for university IT connectivity, cybersecurity collaboration, and international academic research networking, enabling European researchers to lead international collaboration. URL: https://geant.org.

[33] RENATER. *RENATER — Réseau National de télécommunications pour la Technologie, l'Enseignement et la Recherche*. Original description extracted from renater.fr. — AI-generated contextual summary: RENATER maintains active engagement in cybersecurity through its CERT and information security programs, serving over 400 academic institutions with connectivity, security solutions, and federated identity management. URL: https://www.renater.fr.

[34] National research and education network. *National research and education network (NREN) — telecommunications, internet resources and cybersecurity services*. Generic NREN role description; an adopting institution substitutes the NREN of its own country. 2026.

[35] Klaas Wierenga and Licia Florio. "eduroam: Past, Present and Future". In: *Computational Methods in Science and Technology* 11.2 (2005). Last consulted 15 February 2026. Foundational component of modern university IT infrastructure, establishing the concepts and protocols for secure roaming services. eduroam now spans over 100 countries and is a key element of federated identity management for academic institutions., pp. 169–173. DOI: 10.12921/cmst.2005.11.02.169-173. URL: https://cmst.eu/articles/eduroam-past-present-and-future/.

[36] GÉANT. *eduGAIN — Global Interfederation Service*. Original description extracted from edugain.org. — AI-generated contextual summary: for university IT departments, eduGAIN is directly relevant to identity management and access governance, providing a scalable solution for supporting global resource access while maintaining institutional security and user privacy controls. URL: https://edugain.org/.

[37] Peter Weill and Jeanne W. Ross. *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results*. Highly relevant to university governance as it provides actionable models for structuring IT decision-making authority, accountability, and strategic alignment within complex organizations. Harvard Business School Press, 2004. ISBN: 978-1591392538. URL: https://hbsp.harvard.edu/product/4783-HBK-ENG.

[38] IBM Security and Ponemon Institute. *Cost of a Data Breach Report 2024*. Tech. rep. Global all-industry average; the education sector sits below this figure. IBM Security, 2024. URL: https://www.ibm.com/reports/data-breach.

[39] NIST. *Guide to a Secure Enterprise Network Landscape*. Tech. rep. SP 800-215. For university IT infrastructure, this resource is directly relevant as academic institutions increasingly adopt distributed cloud resources and remote access models, making zero-trust security frameworks critical for protecting sensitive research data and institutional systems. National Institute of Standards and Technology, 2021. URL: https://csrc.nist.gov/pubs/sp/800/215/final.

[40] E. Dart, L. Rotman, B. Tierney, M. Hester, and J. Zurawski. "The Science DMZ: A Network Design Pattern for Data-Intensive Science". In: *SC '13: Proceedings of the International Conference on High Performance Computing, Networking, Storage and Analysis* (2013). URL: https://www.es.net/assets/pubs_presos/sc13sciDMZ-final.pdf.

[41] ESnet. *Science DMZ Case Studies*. Energy Sciences Network. ESnet case studies demonstrating how high-speed network infrastructure resolves scientific computing challenges at national laboratories and research institutions, including OSCARS circuit management and Science DMZ architecture. Directly relevant to university IT professionals seeking practical guidance on deploying research data infrastructure. URL: https://www.es.net/science-engagement/knowledge-base/case-studies/.

[42] William Samuelson and Richard Zeckhauser. "Status Quo Bias in Decision Making". In: *Journal of Risk and Uncertainty* 1.1 (1988). Last consulted 15 February 2026. Highly relevant to university IT governance: explains institutional resistance to infrastructure modernization, policy reform, and adoption of new cybersecurity frameworks, illuminating why organizations often persist with suboptimal legacy systems and outdated governance structures., pp. 7–59. DOI: 10.1007/BF00055564. URL: https://link.springer.com/article/10.1007/BF00055564.

[43] OASIS Security Services Technical Committee. *Assertions and Protocols for the OASIS Security Assertion Markup Language (SAML) V2.0*. OASIS Standard. 2005. URL: http://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf.

[44] OASIS Key Management Interoperability Protocol Technical Committee. *Key Management Interoperability Protocol Specification Version 2.1*. OASIS Standard. 2020. URL: https://docs.oasis-open.org/kmip/kmip-spec/v2.1/kmip-spec-v2.1.html.

[45] OASIS PKCS 11 Technical Committee. *PKCS #11 Cryptographic Token Interface Base Specification Version 3.0*. OASIS Standard. 2020. URL: https://docs.oasis-open.org/pkcs11/pkcs11-spec/v3.0/pkcs11-spec-v3.0.html.

[46] E. Rescorla. *The Transport Layer Security (TLS) Protocol Version 1.3*. RFC 8446, Internet Engineering Task Force. 2018. URL: https://datatracker.ietf.org/doc/html/rfc8446.

[47] R. Barnes, J. Hoffman-Andrews, D. McCarney, and J. Kasten. *Automatic Certificate Management Environment (ACME)*. RFC 8555, Internet Engineering Task Force. 2019. URL: https://datatracker.ietf.org/doc/html/rfc8555.

[48] Cloud Native Computing Foundation (CNCF). *OpenTelemetry Specification*. CNCF specification. 2024. URL: https://opentelemetry.io/docs/specs/.

[49] B. Claise, B. Trammell, and P. Aitken. *Specification of the IP Flow Information Export (IPFIX) Protocol for the Exchange of Flow Information*. RFC 7011, Internet Engineering Task Force. 2013. URL: https://datatracker.ietf.org/doc/html/rfc7011.

[50] Open Container Initiative (OCI). *OCI Image Format Specification*. Open Container Initiative specification. 2024. URL: https://github.com/opencontainers/image-spec.

[51] European Commission. *Commission Implementing Decision (EU) 2021/914 of 4 June 2021 on standard contractual clauses for the transfer of personal data to third countries pursuant to Regulation (EU) 2016/679 of the European Parliament and of the Council*. OJ L 199, 7 June 2021, p. 31. CELEX: 32021D0914. Entry into force 27 June 2021; legacy SCCs (Decisions 2001/497/EC and 2010/87/EU) repealed 27 September 2021; transition period for pre-existing contracts ended 27 December 2022 — Direct operational anchor for university adoption of non-EU AI cloud services, paired with a Transfer Impact Assessment and technical safeguards (encryption, pseudonymisation, data classification). 2021. URL: https://eur-lex.europa.eu/eli/dec_impl/2021/914/oj.

[52] InCommon. *InCommon Federation*. Original description extracted from incommon.org. — AI-generated contextual summary: InCommon removes barriers to research and education collaboration through federated identity services and global Wi-Fi access, making it essential infrastructure for modern campus IT operations. URL: https://incommon.org/.

[53] Trusted CI. *Trusted CI — The NSF Cybersecurity Center of Excellence*. Original description extracted from trustedci.org. — AI-generated contextual summary: it addresses unique cybersecurity challenges in higher education, including protection against emerging threats like ransomware while balancing the openness required for collaborative research. URL: https://trustedci.org/.

[54] Multiple sources. *MOVEit Transfer vulnerability and university breaches (UCLA, Stanford Medicine, Georgia, etc.)* Cl0p ransomware group; Progress Software MOVEit zero-day; see e.g., University System of Georgia, UCLA breach notices. — The FBI and CISA joint advisory disseminates known CL0P ransomware IOCs and TTPs: beginning May 27, 2023, CL0P exploited a previously unknown SQL injection vulnerability (CVE-2023-34362) in Progress Software's MOVEit Transfer, installing a web shell called LEMURLOOT to steal data. Major universities including UCLA, Stanford Medicine, and the University System of Georgia were among the victims. 2023–2024. URL: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-158a.

[55] *perfSONAR — Network Measurement Toolkit*. Original description extracted from perfsonar.net. — AI-generated contextual summary: the global infrastructure assists engineering teams in troubleshooting and helps increase productivity when utilizing network resources, making it particularly valuable for universities managing complex research and educational networks. URL: https://www.perfsonar.net/.

[56] *Science DMZ Networks: How Different Are They Really?* NSF Public Access Repository. Last consulted 15 February 2026. Two-year quantitative study finding that Science DMZ networks exhibit lower latency, higher throughput, and lower jitter, but also non-intuitive results. Relevant to universities evaluating Science DMZ deployment for research network performance. 2024. URL: https://doi.org/10.1109/LCN60385.2024.10639626.

[57] European Commission. *Commission Implementing Regulation (EU) 2024/2690 of 17 October 2024 laying down rules for the application of Directive (EU) 2022/2555 (NIS2) regarding technical and methodological requirements for cybersecurity risk-management measures*. 2024. URL: https://eur-lex.europa.eu/eli/reg_impl/2024/2690/oj.

[58] NIST. *Security and Privacy Controls for Information Systems and Organizations*. Tech. rep. NIST SP 800-53 Rev. 5. For academic institutions, adopting these controls strengthens cybersecurity posture while meeting requirements under the Federal Information Security Modernization Act (FISMA) and other regulatory mandates that apply to federally-funded research operations. National Institute of Standards and Technology, 2020. DOI: 10.6028/NIST.SP.800-53r5. URL: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.

[59] R. Gerhards. *The Syslog Protocol*. RFC 5424, Internet Engineering Task Force. 2009. URL: https://datatracker.ietf.org/doc/html/rfc5424.

[60] REN-ISAC. *REN-ISAC — Research and Education Networking ISAC*. Original description extracted from ren-isac.net/what-we-do/Overview.html. — AI-generated contextual summary: members gain access to a community of cybersecurity experts and professional development opportunities including webinars and workshops, strengthening institutional security postures. URL: https://ren-isac.net/what-we-do/Overview.html.

[61] FIRST. *FIRST — Forum of Incident Response and Security Teams*. Original description extracted from first.org. — AI-generated contextual summary: for universities, FIRST membership offers frameworks and community resources essential for developing robust IT security operations and coordinated incident handling capabilities. URL: https://www.first.org/.